

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT IoT (INT4410)

TÊN ĐỀ TÀI

BẢO MẬT MQTT BẰNG MOSQUITTO VÀ PAHO PYTHON

Mã học phần	INT4410
Lớp học phần	253INT441001
Giảng viên hướng dẫn	Hồ Nhật Minh
Sinh viên/Nhóm	Mai Thị Thảo Vy
Thành viên - MSSV	Mai Thị Thảo Vy – 231A010112
Link repo GitHub	https://maivy111205.github.io/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython/
Ngày nộp	[dd/mm/yyyy]

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Bảo mật MQTT bằng Mosquitto và Paho Python
Mã đề tài	12
Sinh viên/Nhóm	Mai Thị Thảo Vy – 231A010112
Repo GitHub	https://maivy111205.github.io/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython/
Bản báo cáo	231A010112_Mai Thị Thảo Vy_12_BaoCao.docx
Bản trình chiếu	231A010112_Mai Thị Thảo Vy_12_Slide.pptx
Sản phẩm chính	Code Python Publisher/Subscriber, cấu hình Mosquitto Broker, file ACL, file cấu hình, log kiểm thử, sơ đồ mô hình MQTT
Ngày nộp	[dd/mm/yyyy]

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- Họ tên người cam kết: Mai Thị Thảo Vy
- Ngày cam kết: [...../...../.....]
- Chữ ký: [.....]

MỤC LỤC

MỤC LỤC

THÔNG TIN VÀ CAM KẾT NỘP BÀI	2
Cam kết an toàn và học thuật.....	2
MỤC LỤC.....	3
DANH MỤC TỪ VIẾT TẮT	5
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	8
1.1. Bối cảnh và lý do chọn đề tài.....	8
1.2. Phát biểu vấn đề	8
1.3. Mục tiêu của đề tài	8
1.4. Đối tượng, phạm vi và giới hạn an toàn	9
1.4.1. Đối tượng nghiên cứu	9
1.4.2. Phạm vi nghiên cứu	9
1.4.3. Giới hạn của đề tài.....	9
1.5. Sản phẩm dự kiến và đóng góp	9
1.6. Cấu trúc báo cáo.....	10
Bảng đối chiếu mục tiêu và đầu ra.....	10
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	11
2.1. Kiến trúc, giao thức hoặc công nghệ nền	11
2.2. Khái niệm bảo mật liên quan	11
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài	11
2.4. Chuẩn, tài liệu và công cụ GitHub.....	12
2.5. Công trình hoặc giải pháp liên quan	12
2.6. Tiểu kết Chương 2	14
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	15
3.1. Phương pháp thực hiện.....	15
3.2. Mô hình/kiến trúc đề xuất	16
3.3. Môi trường, công cụ và dữ liệu	17
3.3.1. Môi trường triển khai.....	17
3.3.2. Công cụ sử dụng.....	17
3.3.3. Dữ liệu thử nghiệm	17
3.4. Quy trình triển khai	18

3.5. Tiêu chí đánh giá	18
3.6. Giới hạn an toàn và đạo đức.....	19
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	19
4.1. Chuẩn bị môi trường.....	19
4.2. Thành phần sản phẩm	20
4.3. Kịch bản thử nghiệm/đánh giá.....	20
4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm	20
5. KẾT QUẢ VÀ THẢO LUẬN	20
5.1. Kết quả chính.....	20
5.2. Bảng tổng hợp kết quả	21
5.3. Đối chiếu mục tiêu	21
5.4. Hạn chế.....	21
6. ĐÁNH GIÁ BẢO MẬT	21
6.1. Tài sản và dữ liệu cần bảo vệ.....	21
6.2. Mối đe dọa và lỗ hổng	22
6.3. Ma trận rủi ro	22
6.4. Biện pháp giảm thiểu và ưu tiên	23
6.5. Đánh giá an toàn sau xử lý	23
7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	23
7.1. Kết luận	23
7.2. Hướng phát triển	23
TÀI LIỆU THAM KHẢO	23
PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP.....	25
PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP	25
PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP	25

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1		
2		
3		
4		
5		
6		

PHIẾU XÁC ĐỊNH YÊU CẦU RIÊNG CỦA ĐỀ TÀI

Mã và tên đề tài	Đề tài số 12 - Bảo mật MQTT bằng Mosquitto và Paho Python
Hướng đề tài	Hướng B
Vấn đề bảo mật cốt lõi	Trong hệ thống IoT sử dụng MQTT, dữ liệu cảm biến có thể bị truy cập trái phép nếu MQTT Broker không được cấu hình bảo mật. Các nguy cơ chính gồm lộ dữ liệu, giả mạo dữ liệu gửi lên hệ thống và người dùng không có quyền vẫn có thể kết nối vào Broker. Đề tài tập trung bảo vệ tài sản dữ liệu MQTT bằng cơ chế xác thực Username/Password và phân quyền truy cập Topic.
Ba mục tiêu bắt buộc	Mục tiêu 1: Triển khai MQTT Broker cục bộ bằng Mosquitto và kiểm tra khả năng hoạt động của hệ thống. Mục tiêu 2: Xây dựng chương trình MQTT Publisher và Subscriber bằng Python sử dụng thư viện Paho MQTT để gửi và nhận dữ liệu. Mục tiêu 3: Cấu hình bảo mật cho MQTT Broker gồm xác thực người dùng bằng Username/Password và kiểm soát quyền truy cập Topic bằng ACL.
Sản phẩm/đầu ra bắt buộc	MQTT Broker Mosquitto chạy trên môi trường local. Chương trình mqtt_pub.py gửi dữ liệu MQTT. Chương trình mqtt_sub.py nhận dữ liệu MQTT và lưu log. File cấu hình mosquitto.conf. File tài khoản xác thực người dùng. File ACL phân quyền Topic. README hướng dẫn cài đặt và sử dụng. Hình ảnh, log minh chứng quá trình Publish/Subscribe thành công và kiểm tra bảo mật.
Nguồn GitHub/tool chính	Eclipse Mosquitto: https://github.com/eclipse-mosquitto/mosquitto Eclipse Paho MQTT Python: https://github.com/eclipse-paho/paho.mqtt.python Repo thực hiện đề tài: https://maivy111205.github.io/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython/
Minh chứng sẽ thu thập	Screenshot MQTT Broker Mosquitto đang chạy. Screenshot Python Subscriber kết nối thành công và nhận dữ liệu. Screenshot Publisher gửi dữ liệu MQTT. Log hoạt động của Broker. File code mqtt_pub.py, mqtt_sub.py. File cấu hình mosquitto.conf. Bảng kiểm tra quyền truy cập hợp lệ và không hợp lệ.

	Commit GitHub lưu trữ tiến độ thực hiện.
Phạm vi an toàn	Đề tài được triển khai trong môi trường Local trên máy tính cá nhân Windows. MQTT Broker Mosquitto chạy trên localhost, dữ liệu được tạo giả lập bằng Python, không sử dụng thiết bị IoT thật hoặc dữ liệu thực tế. Phạm vi thử nghiệm chỉ phục vụ mục đích học tập, không triển khai MQTT qua Internet hoặc môi trường sản xuất.

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong những năm gần đây, Internet of Things (IoT) đã được ứng dụng rộng rãi trong nhiều lĩnh vực như nhà thông minh, nông nghiệp, y tế, giao thông và sản xuất công nghiệp. Các thiết bị IoT thường xuyên trao đổi dữ liệu thông qua mạng Internet để giám sát và điều khiển từ xa. Trong số các giao thức truyền thông được sử dụng, MQTT (Message Queuing Telemetry Transport) được đánh giá là một giao thức phổ biến nhờ đặc điểm nhẹ, tốc độ truyền nhanh và phù hợp với các thiết bị có tài nguyên hạn chế.

Tuy nhiên, nếu hệ thống MQTT không được cấu hình bảo mật phù hợp thì bất kỳ thiết bị hoặc người dùng nào cũng có thể kết nối vào Broker để gửi hoặc nhận dữ liệu. Điều này có thể dẫn đến nguy cơ rò rỉ thông tin, giả mạo dữ liệu cảm biến hoặc thực hiện các cuộc tấn công làm gián đoạn hoạt động của hệ thống IoT.

Xuất phát từ thực tế trên, đề tài "Bảo mật MQTT bằng Mosquitto và Paho Python" được lựa chọn nhằm nghiên cứu và triển khai cơ chế xác thực người dùng, phân quyền truy cập theo Topic và kiểm tra hoạt động của hệ thống trong các trường hợp được phép và không được phép truy cập. Qua đó giúp nâng cao mức độ an toàn cho hệ thống truyền thông IoT sử dụng giao thức MQTT.

1.2. Phát biểu vấn đề

Trong mô hình MQTT, Broker là thành phần trung tâm tiếp nhận và phân phối dữ liệu giữa Publisher và Subscriber. Nếu Broker cho phép truy cập ẩn danh hoặc không áp dụng cơ chế phân quyền thì các nguy cơ sau có thể xảy ra:

- + Người dùng trái phép kết nối vào Broker.
- + Đọc dữ liệu của các thiết bị IoT.
- + Gửi dữ liệu giả mạo lên hệ thống.
- + Làm sai lệch thông tin cảm biến.
- + Ảnh hưởng đến tính toàn vẹn và tính bảo mật của dữ liệu.

Để giảm thiểu các nguy cơ trên, đề tài tập trung triển khai cơ chế xác thực bằng tên đăng nhập và mật khẩu kết hợp với danh sách điều khiển truy cập (ACL), giúp giới hạn quyền Publish và Subscribe theo từng Topic.

1.3. Mục tiêu của đề tài

Đề tài “Bảo mật MQTT bằng Mosquitto và Paho Python” hướng đến các mục tiêu sau:

Mục tiêu 1: Triển khai thành công MQTT Broker cục bộ bằng Mosquitto, kiểm tra khả năng khởi động và quản lý kết nối Client trên môi trường Windows.

Mục tiêu 2: Xây dựng chương trình MQTT Publisher và Subscriber bằng Python sử dụng thư viện Eclipse Paho MQTT, thực hiện gửi và nhận dữ liệu thông qua Topic `iot/sensor/temp`.

Mục tiêu 3: Thiết lập cơ chế xác thực người dùng (Authentication) bằng Username/Password trên MQTT Broker nhằm ngăn chặn truy cập trái phép.

Mục tiêu 4: Cấu hình cơ chế phân quyền ACL (Access Control List) để kiểm soát quyền Publish và Subscribe của từng tài khoản trên các Topic MQTT.

Mục tiêu 5: Thử nghiệm và đánh giá khả năng hoạt động của hệ thống trong các trường hợp hợp lệ và không hợp lệ.

1.4. Đối tượng, phạm vi và giới hạn an toàn

1.4.1. Đối tượng nghiên cứu

Giao thức MQTT.

Mosquitto Broker.

Eclipse Paho MQTT Python.

Cơ chế xác thực và phân quyền truy cập.

1.4.2. Phạm vi nghiên cứu

Đề tài được triển khai trên máy tính cá nhân sử dụng hệ điều hành Windows. MQTT Broker được cài đặt và chạy trên môi trường cục bộ (localhost). Dữ liệu được mô phỏng bằng chương trình Python và không sử dụng thiết bị IoT thực tế.

1.4.3. Giới hạn của đề tài

Đề tài chưa triển khai:

- + TLS/SSL.
- + Chứng chỉ số.
- + MQTT qua Internet.
- + Kết nối Cloud.
- + Thiết bị ESP32 hoặc Raspberry Pi.

1.5. Sản phẩm dự kiến và đóng góp

Sau khi hoàn thành đề tài sẽ thu được các sản phẩm sau:

- + MQTT Broker Mosquitto hoạt động trên máy cục bộ.
- + Chương trình mqtt_pub.py.
- + Chương trình mqtt_sub.py.
- + File cấu hình mosquitto.conf.
- + File phân quyền ACL.
- + File chứa tài khoản người dùng.

- + Nhật ký hoạt động của Broker.
- + Hình ảnh minh họa Publish thành công.
- + Hình ảnh minh họa Subscribe thành công.
- + Hình ảnh minh họa truy cập bị từ chối khi sai quyền.
- + README hướng dẫn cài đặt và sử dụng.

1.6. Cấu trúc báo cáo

Báo cáo gồm sáu chương. Chương 1 trình bày tổng quan về đề tài, mục tiêu và phạm vi nghiên cứu. Chương 2 giới thiệu cơ sở lý thuyết liên quan đến MQTT, Mosquitto và Paho MQTT Python. Chương 3 trình bày phương pháp thực hiện và mô hình triển khai hệ thống. Chương 4 mô tả quá trình cài đặt, cấu hình và kết quả thực nghiệm. Chương 5 đánh giá các rủi ro bảo mật và đề xuất biện pháp giảm thiểu. Cuối cùng, Chương 6 trình bày kết luận và hướng phát triển của đề tài.

Bảng đối chiếu mục tiêu và đầu ra

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Cài đặt Mosquitto Broker	Broker chạy thành công	Chương 4
MT-02	Viết Publisher và Subscriber	Publish và Subscribe thành công	Chương 4
MT-03	Cấu hình User và Password	Đăng nhập thành công	Chương 4
MT-04	Thiết lập ACL	Kiểm tra đúng quyền và sai quyền	Chương 5

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền

Hệ thống trong đề tài được xây dựng theo mô hình Publish/Subscribe của giao thức MQTT. Trong mô hình này, Publisher chịu trách nhiệm gửi dữ liệu, Subscriber nhận dữ liệu và Mosquitto Broker đóng vai trò trung gian tiếp nhận, xử lý và chuyển tiếp dữ liệu giữa các Client.

Luồng hoạt động của hệ thống như sau:



Hình 2.1 Mô hình truyền thông Publish/ Subscribe trong MQTT

Chú thích:

Publisher: Thiết bị/ chương trình gửi dữ liệu MQTT.

Subscriber: Thiết bị/ chương trình nhận dữ liệu.

Broker: Trung gian quản lý kết nối và phân phối message.

Topic: Kênh định danh dữ liệu MQTT.

2.2. Khái niệm bảo mật liên quan

Các khái niệm bảo mật được áp dụng trong đề tài gồm:

- + Authentication (Xác thực): Kiểm tra danh tính người dùng thông qua tên đăng nhập và mật khẩu.
- + Authorization (Phân quyền): Quy định người dùng được phép Publish hoặc Subscribe trên các Topic cụ thể.
- + Topic: Kênh truyền dữ liệu giữa Publisher và Subscriber.
- + Broker: Thành phần trung tâm quản lý kết nối và truyền dữ liệu.
- + ACL (Access Control List): Danh sách quy định quyền truy cập của từng người dùng.
- + CIA: Ba mục tiêu bảo mật gồm tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) và tính sẵn sàng (Availability).

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

Đề tài thuộc nhóm B nên tập trung vào:

- + Đặc điểm của giao thức MQTT.
- + Cơ chế Publish/Subscribe.
- + Xác thực bằng Username và Password.
- + Phân quyền bằng ACL.
- + Cấu hình Mosquitto Broker an toàn.

+ Thư viện Eclipse Paho MQTT Python.

2.4. Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	OASIS MQTT Version 5.0 Standard	https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html	Kiến trúc MQTT, Publish/Subscribe, Topic, Broker	14/07/2026
2	Eclipse Mosquitto Repository	https://github.com/eclipse-mosquitto/mosquitto	Cài đặt MQTT Broker, mosquitto_pub, mosquitto_sub, cấu hình Broker	14/07/2026
3	Eclipse Paho MQTT Python	https://github.com/eclipse-paho/paho.mqtt.python	Xây dựng Publisher và Subscriber bằng Python	14/07/2026
4	Mosquitto Documentation	https://mosquitto.org/documentation/	Cấu hình Username/Password, ACL	14/07/2026
5	Python Documentation	https://docs.python.org/3/	Ngôn ngữ Python sử dụng trong Client MQTT	14/07/2026
6	Mai Thi Thao Vy – MQTT Security Project	https://maivy111205.github.io/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython/	Sản phẩm thực nghiệm, code, cấu hình, kết quả kiểm thử	14/07/2026

2.5. Công trình hoặc giải pháp liên quan

Hiện nay, bảo mật trong hệ thống IoT sử dụng giao thức MQTT đang nhận được nhiều sự quan tâm do MQTT được triển khai rộng rãi trong các hệ thống giám sát, điều khiển từ xa và thiết bị thông minh. Một số giải pháp và tài liệu liên quan đã được nghiên cứu nhằm nâng cao mức độ an toàn trong quá trình truyền nhận dữ liệu MQTT.

Giải pháp thứ nhất: Eclipse Mosquitto MQTT Broker

Eclipse Mosquitto là một MQTT Broker mã nguồn mở được sử dụng phổ biến trong các hệ thống IoT. Mosquitto hỗ trợ các cơ chế bảo mật như xác thực bằng Username/Password, phân quyền truy cập bằng ACL (Access Control List), mã hóa kết nối bằng TLS/SSL và quản lý Client kết nối đến Broker.

Trong đề tài này, Mosquitto được sử dụng làm Broker trung tâm để tiếp nhận dữ liệu từ Publisher và phân phối dữ liệu đến Subscriber. Cơ chế xác thực và phân quyền của Mosquitto được khai thác nhằm giới hạn quyền truy cập của từng người dùng, tránh tình trạng người dùng không hợp lệ có thể gửi hoặc đọc dữ liệu MQTT.

Giải pháp thứ hai: Eclipse Paho MQTT Python Client

Eclipse Paho MQTT Python là thư viện hỗ trợ lập trình Client MQTT bằng ngôn ngữ Python. Thư viện này cung cấp các hàm cần thiết để xây dựng chương trình Publisher và Subscriber, thực hiện kết nối đến MQTT Broker, đăng ký Topic, gửi dữ liệu và nhận dữ liệu.

Trong đề tài, Paho MQTT Python được sử dụng để xây dựng hai chương trình:

`mqt_pub.py`: Đóng vai trò Publisher, gửi dữ liệu cảm biến giả lập đến MQTT Broker.

`mqt_sub.py`: Đóng vai trò Subscriber, nhận dữ liệu từ Topic đã đăng ký và hiển thị kết quả.

Việc sử dụng Paho Python giúp mô phỏng quá trình trao đổi dữ liệu giữa các thiết bị IoT mà không cần sử dụng phần cứng thực tế.

Giải pháp thứ ba: Cấu hình bảo mật MQTT bằng Username/Password và ACL

Một hệ thống MQTT mặc định có thể cho phép Client kết nối mà không cần xác thực nếu Broker được cấu hình chế độ Anonymous. Điều này tạo ra nguy cơ bị truy cập trái phép hoặc giả mạo dữ liệu.

Giải pháp sử dụng Username/Password kết hợp với ACL giúp kiểm soát quyền truy cập của từng Client. Ví dụ:

Người dùng `sensor` chỉ có quyền Publish dữ liệu lên Topic `iot/sensor/temp`.

Người dùng `dashboard` chỉ có quyền Subscribe để theo dõi dữ liệu cảm biến.

So với việc chỉ sử dụng Username/Password, ACL cung cấp thêm lớp kiểm soát quyền truy cập chi tiết hơn, giúp đảm bảo nguyên tắc phân quyền tối thiểu (Least Privilege).

So sánh các giải pháp liên quan:

Giải pháp	Ưu điểm	Hạn chế
MQTT mặc định không xác thực	Cấu hình đơn giản, dễ triển khai	Không đảm bảo bảo mật, dễ bị truy cập trái phép
MQTT sử dụng Username/Password + ACL	Xác thực được người dùng	Chưa kiểm soát chi tiết quyền truy cập
MQTT kết hợp Username/Password + ACL	Kiểm soát quyền Publish/Subscribe theo Topic	Cần cấu hình Broker phức tạp hơn
MQTT kết hợp TLS/SSL	Bảo vệ dữ liệu khi truyền trên mạng	Yêu cầu quản lý chứng chỉ và tài nguyên cao hơn

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày các kiến thức nền tảng liên quan đến hệ thống MQTT và các cơ chế bảo mật được áp dụng trong đề tài. Cụ thể, chương đã giới thiệu mô hình hoạt động Publish/Subscribe của MQTT, vai trò của MQTT Broker, Publisher và Subscriber trong quá trình trao đổi dữ liệu.

Bên cạnh đó, chương cũng trình bày các khái niệm bảo mật quan trọng gồm Authentication, Authorization, ACL và mô hình bảo mật CIA. Đây là những thành phần cần thiết để xây dựng một hệ thống MQTT có khả năng kiểm soát người dùng và bảo vệ dữ liệu IoT.

Thông qua việc tìm hiểu Mosquitto Broker và thư viện Eclipse Paho MQTT Python, đề tài có cơ sở để triển khai mô hình thực nghiệm gồm Broker, Publisher và Subscriber trên môi trường Windows. Các cơ chế xác thực bằng Username/Password và phân quyền bằng ACL sẽ được áp dụng trong quá trình cấu hình hệ thống.

Trong chương tiếp theo, đề tài sẽ trình bày phương pháp thực hiện, mô hình kiến trúc hệ thống, môi trường triển khai, quy trình cấu hình Mosquitto Broker và kế hoạch đánh giá kết quả bảo mật.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài được thực hiện theo phương pháp nghiên cứu kết hợp giữa lý thuyết và thực nghiệm. Trước tiên, đề tài tìm hiểu các kiến thức liên quan đến giao thức MQTT, mô hình Publish/Subscribe, MQTT Broker, cơ chế xác thực người dùng và phân quyền truy cập trong hệ thống IoT.

Sau quá trình nghiên cứu lý thuyết, hệ thống thử nghiệm được xây dựng trên môi trường máy tính cá nhân sử dụng hệ điều hành Windows. MQTT Broker được triển khai bằng phần mềm Eclipse Mosquitto, trong khi các chương trình Publisher và Subscriber được xây dựng bằng ngôn ngữ Python kết hợp thư viện Eclipse Paho MQTT.

Quá trình thực hiện đề tài gồm các bước chính:

Bước 1: Nghiên cứu giao thức MQTT

Tìm hiểu mô hình hoạt động của MQTT, các thành phần trong hệ thống gồm Publisher, Subscriber và Broker. Phân tích các vấn đề bảo mật thường gặp khi triển khai MQTT như truy cập trái phép, giả mạo dữ liệu và lộ thông tin truyền nhận.

Bước 2: Cài đặt và cấu hình MQTT Broker

Cài đặt Eclipse Mosquitto trên hệ điều hành Windows. Sau đó cấu hình Broker với các thành phần bảo mật:

Tắt chế độ truy cập Anonymous.

Tạo tài khoản người dùng bằng Username/Password.

Thiết lập ACL để giới hạn quyền Publish và Subscribe.

Cấu hình Topic sử dụng trong hệ thống.

Bước 3: Xây dựng chương trình MQTT Client bằng Python

Sử dụng thư viện Paho MQTT Python để xây dựng hai chương trình:

Publisher gửi dữ liệu cảm biến mô phỏng.

Subscriber nhận và hiển thị dữ liệu từ Broker.

Bước 4: Kiểm thử và đánh giá

Thực hiện các kịch bản kiểm tra:

Client có tài khoản hợp lệ kết nối thành công.

Publisher gửi dữ liệu đúng Topic.

Subscriber nhận dữ liệu thành công.

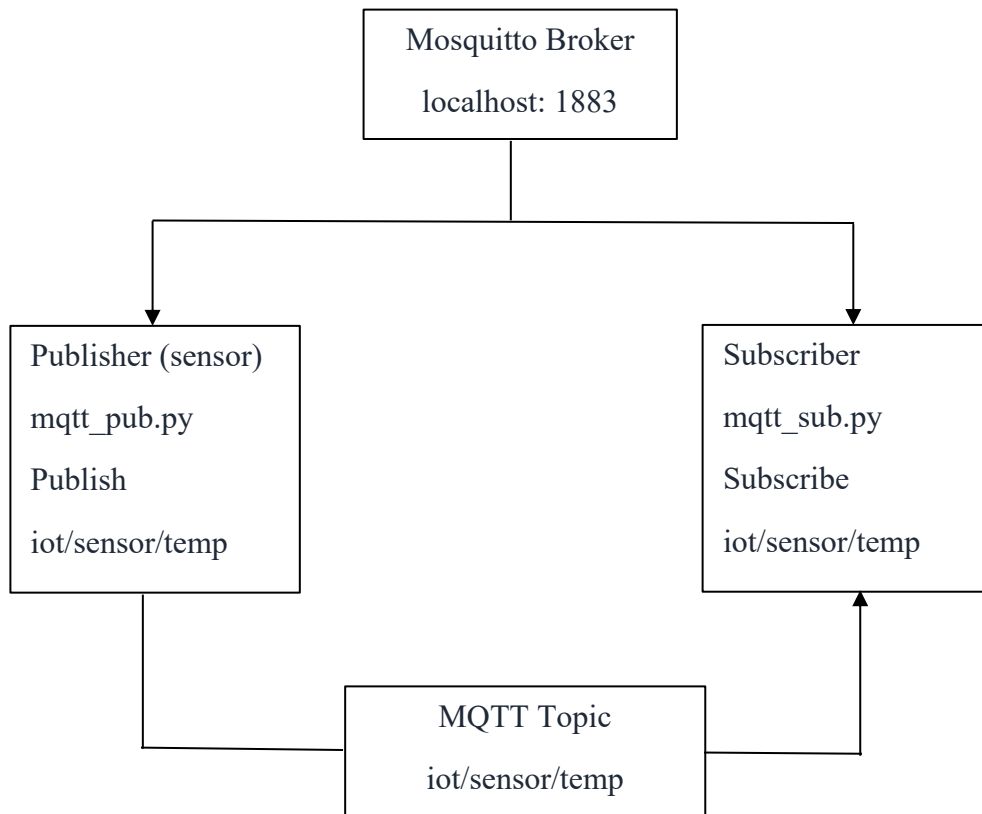
Người dùng không có quyền bị từ chối truy cập.

Kết quả kiểm thử được ghi nhận thông qua log của Mosquitto Broker và kết quả hiển thị trên chương trình Python.

3.2. Mô hình/kiến trúc đề xuất

Hệ thống trong đề tài được thiết kế theo mô hình MQTT Publish/Subscribe, trong đó Mosquitto Broker đóng vai trò trung tâm tiếp nhận, xác thực và phân phối dữ liệu giữa Publisher và Subscriber. Toàn bộ quá trình trao đổi dữ liệu diễn ra thông qua Topic `iot/sensor/temp`.

Mô hình tổng thể:



Hình 3.1. Mô hình hệ thống MQTT Publish/Subscribe sử dụng Mosquitto Broker

Mô tả hoạt động của hệ thống:

Publisher: được xây dựng bằng chương trình `mqtt_pub.py`, có nhiệm vụ gửi dữ liệu cảm biến lên Broker thông qua Topic `iot/sensor/temp`. Publisher sử dụng tài khoản `sensor` với mật khẩu được tạo bằng công cụ `mosquitto_passwd` để thực hiện quá trình xác thực với MQTT Broker.

Mosquitto Broker: thành phần trung tâm của hệ thống, chịu trách nhiệm quản lý các kết nối MQTT, xác thực người dùng bằng Username/Password, kiểm tra quyền truy cập thông qua ACL và chuyển tiếp dữ liệu từ Publisher đến Subscriber. Broker được cấu hình chạy trên localhost, sử dụng cổng 1883.

Subscriber: được xây dựng bằng chương trình `mqtt_sub.py`, sử dụng tài khoản `dashboard` để đăng ký nhận dữ liệu từ Topic `iot/sensor/temp`. Sau khi nhận dữ liệu thành công, chương trình hiển thị nội dung trên màn hình và lưu vào tệp nhật ký `mqtt_log.txt`.

Qua mô hình trên có thể thấy Mosquitto Broker đóng vai trò kiểm soát toàn bộ quá trình truyền thông. Chỉ những người dùng được xác thực và có quyền truy cập phù hợp mới được phép Publish hoặc Subscribe dữ liệu, góp phần nâng cao tính bảo mật cho hệ thống MQTT.

3.3. Môi trường, công cụ và dữ liệu

3.3.1. Môi trường triển khai

Hệ thống được triển khai trên máy tính cá nhân và các thông tin:

Thành phần	Thông tin
Hệ điều hành	Windows 11
MQTT Broker	Eclipse Mosquitto 2.1.2
Ngôn ngữ lập trình	Python 3.14
MQTT Client Library	Eclipse Paho MQTT Python
Công cụ quản lý mã nguồn	GitHub
Môi trường chạy	Localhost

3.3.2. Công cụ sử dụng

Eclipse Mosquitto: Mosquitto được sử dụng làm MQTT Broker nhằm quản lý quá trình truyền nhận dữ liệu giữa các Client.

Các chức năng sử dụng:

- + Chạy MQTT Broker.
- + Cấu hình User Authentication.
- + Cấu hình ACL.
- + Kiểm tra log kết nối.

Eclipse Paho MQTT Python: Paho MQTT Python được sử dụng để xây dựng MQTT Client.

Các chức năng:

- + Kết nối Broker.
- + Publish dữ liệu.
- + Subscribe Topic.
- + Nhận Message.

Python: được lựa chọn vì có cú pháp đơn giản, hỗ trợ nhiều thư viện IoT và phù hợp để mô phỏng thiết bị cảm biến.

3.3.3. Dữ liệu thử nghiệm

Dữ liệu trong hệ thống được mô phỏng dưới dạng giá trị nhiệt độ.

Ví dụ:

Topic: iot/sensor/temp.

Payload: 30

Trong thực tế, dữ liệu này có thể thay thế bằng dữ liệu từ cảm biến nhiệt độ, độ ẩm hoặc các thiết bị IoT khác.

3.4. Quy trình triển khai

Quy trình triển khai hệ thống gồm các bước sau:

Cài đặt Mosquitto → Cấu hình Broker (Mosquitto.conf) → Tạo User Password → Thiết lập ACL → Chạy MQTT Broker → Chạy Subscriber Python → Gửi dữ liệu Publisher → Kiểm tra kết quả.

Các bước thực hiện chi tiết:

Bước 1: Khởi động MQTT Broker

Mosquitto được chạy bằng lệnh: `mosquitto -c mosquitto.conf -v`

Kết quả:

`mosquitto version 2.1.2 running`

`Opening ipv4 listen socket on port 1883`

Bước 2: Khởi động Subscriber

Chương trình: `mqtt_sub.py`

Kết quả: `Connected to Broker`

Subscriber chờ nhận dữ liệu từ Topic: `iot/sensor/temp`

Bước 3: Gửi dữ liệu Publisher

Publisher gửi dữ liệu:

Topic:

`iot/sensor/temp`

Message:

`30`

Bước 4: Kiểm tra kết quả:

Subscriber nhận được:

=====

Message Received

Topic: `iot/sensor/temp`

Payload: `30`

=====

Kết quả này chứng minh hệ thống MQTT hoạt động đúng theo mô hình Publisher/ Subscribe.

3.5. Tiêu chí đánh giá

Các tiêu chí giúp đánh giá khả năng hoạt động cũng như mức độ bảo mật của hệ thống MQTT sau khi được cấu hình.

STT	Tiêu chí	Phương pháp kiểm tra	Kết quả mong đợi
1	MQTT Broker hoạt động	Kiểm tra log Mosquitto	Broker chạy thành công
2	Xác thực người dùng	Đăng nhập bằng Username/Password	Client hợp lệ được phép truy cập
3	Publish dữ liệu	Gửi Message từ Publisher	Broker nhận dữ liệu
4	Subscribe dữ liệu	Subscribe đăng ký Topic	Nhận được dữ liệu
5	Phân quyền ACL	Kiểm tra quyền truy cập	Người dùng sai quyền bị từ chối
6	Ghi log hoạt động	Kiểm tra file log	Lưu được lịch sử kết nối

3.6. Giới hạn an toàn và đạo đức

Hệ thống trong đề tài chỉ được triển khai và thử nghiệm trong môi trường cục bộ (localhost) trên máy tính cá nhân. Các kết nối MQTT được thực hiện giữa Mosquitto Broker, Publisher và Subscriber do sinh viên xây dựng nhằm mục đích học tập và nghiên cứu bảo mật IoT.

Dữ liệu sử dụng trong quá trình thử nghiệm là dữ liệu cảm biến giả lập, không chứa thông tin cá nhân hoặc dữ liệu thực tế từ thiết bị IoT. Các tài khoản MQTT được tạo riêng cho mục đích kiểm thử, bao gồm username, password và quyền truy cập Topic.

Các thông tin nhạy cảm như mật khẩu người dùng, file password và cấu hình phân quyền ACL không được công khai trên GitHub. Repo chỉ lưu các file cấu hình mẫu và hướng dẫn cài đặt để đảm bảo an toàn thông tin.

Trong quá trình thực hiện, đề tài chỉ kiểm tra các chức năng xác thực, phân quyền và truyền nhận dữ liệu MQTT trong phạm vi được cho phép. Không thực hiện các hành động tấn công vào hệ thống bên ngoài, không thu thập dữ liệu trái phép, không quét mạng hoặc khai thác các thiết bị IoT không thuộc quyền sở hữu.

Mục tiêu của đề tài là đánh giá khả năng bảo mật cơ bản của MQTT Broker thông qua cơ chế Username/Password và ACL, đồng thời đề xuất các biện pháp nâng cao an toàn như sử dụng TLS/SSL trong hướng phát triển tiếp theo.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

[Mô tả các bước cài đặt/cấu hình; chỉ giữ các lệnh cần thiết để người khác có thể tái hiện.]

.....

4.2. Thành phần sản phẩm

ST T	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1				
2				
3				
4				
5				
6				

4.3. Kịch bản thử nghiệm/đánh giá

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01					
TC-02					
TC-03					
TC-04					
TC-05					

4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm

[Tóm tắt lệnh chạy/quy trình sử dụng; dẫn tới README chi tiết; nêu điều kiện để tái hiện kết quả.]

.....
.....

5. KẾT QUẢ VÀ THẢO LUẬN

5.1. Kết quả chính

[Trình bày kết quả bằng bảng, hình, log, screenshot hoặc checklist có dữ liệu; giải thích ý nghĩa của từ ngữ kết quả.]

.....

.....
.....

5.2. Bảng tổng hợp kết quả

Tiêu chí	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng

5.3. Đối chiếu mục tiêu

[Đối chiếu từng mục tiêu ở Mục 1.3 với bằng chứng đã thu được; giải thích mục tiêu chưa đạt nếu có.]

.....

5.4. Hạn chế

[Nêu trung thực giới hạn môi trường, dữ liệu, thiết bị, phương pháp hoặc phạm vi kiểm thử.]

.....

6. ĐÁNH GIÁ BẢO MẬT

6.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú

6.2. Môi đe dọa và lỗ hổng

ID	Tài sản	Môi đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01					
T-02					
T-03					
T-04					
T-05					
T-06					

6.3. Ma trận rủi ro

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01						
R-02						
R-03						
R-04						
R-05						
R-06						
Gợi ý: Có thể tính Điểm rủi ro = Khả năng × Tác động. Nêu rõ thang phân loại thấp, trung bình, cao và nghiêm trọng mà nhóm sử dụng.						

6.4. Biện pháp giảm thiểu và ưu tiên

[Ưu tiên biện pháp theo rủi ro; nêu chủ thể thực hiện, chi phí/độ khó và cách xác minh hiệu quả.]

.....
.....

6.5. Đánh giá an toàn sau xử lý

[Mô tả rủi ro còn lại, điều kiện chấp nhận và các kiểm soát cần theo dõi định kỳ.]

.....

7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

[Tóm tắt vấn đề, cách làm, kết quả nổi bật và mức độ hoàn thành mục tiêu; không đưa dữ liệu mới.]

.....
.....

7.2. Hướng phát triển

[Nêu 2-4 hướng phát triển thực tế: mở rộng thiết bị/dữ liệu, tự động hóa kiểm thử, cải thiện kiểm soát hoặc đánh giá sâu hơn.]

.....

TÀI LIỆU THAM KHẢO

Yêu cầu: Có ít nhất 5 nguồn; bắt buộc có repo GitHub/tool chính. Ghi tác giả/tổ chức, tên tài liệu/repo, URL, phiên bản hoặc branch/tag nếu dùng, ngày truy cập và phần đã sử dụng.

[1] OASIS, MQTT Version 5.0, OASIS Standard, 2019. [Online]. Available:

<https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Kiến trúc MQTT, mô hình Publish/Subscribe, Topic, Client, Broker).

[2] Eclipse Foundation, Eclipse Mosquitto: An Open Source MQTT Broker, Eclipse Mosquitto GitHub Repository. [Online]. Available:

<https://github.com/eclipse-mosquitto/mosquitto>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Cài đặt MQTT Broker, cấu hình mosquitto.conf, công cụ mosquitto_pub và mosquitto_sub).

[3] Eclipse Foundation, Eclipse Paho MQTT Python Client, Eclipse Paho MQTT Python GitHub Repository. [Online]. Available:

<https://github.com/eclipse-paho/paho.mqtt.python>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Xây dựng chương trình Publisher và Subscriber bằng Python).

[4] Eclipse Mosquitto, Mosquitto Documentation. [Online]. Available:

<https://mosquitto.org/documentation/>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Cấu hình xác thực Username/Password, ACL và quản lý Broker).

[5] Python Software Foundation, Python 3 Documentation. [Online]. Available:

<https://docs.python.org/3/>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Ngôn ngữ Python để xây dựng chương trình MQTT Client).

[6] National Institute of Standards and Technology (NIST), Cybersecurity for IoT Device Manufacturers: Considerations for Managing IoT Device Cybersecurity Risk (NISTIR 8259), 2020. [Online]. Available:

<https://doi.org/10.6028/NIST.IR.8259>

Accessed: Jul. 14, 2026.

(Phần sử dụng: Phân tích rủi ro bảo mật IoT, xác thực, bảo vệ dữ liệu).

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

ten-nhom-ten-de-tai/
 README.md
 report/
 slides/
 src/
 configs/
 data/
 results/
 references/

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1					
2					
3					
4					
5					
6					

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☐ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☐ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☐ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☐ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☐ Đạt ☐

STT	Nội dung kiểm tra	Trạng thái
		Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☐ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☐ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☐ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☐ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☐ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☐ Đạt ☐ Chưa đạt